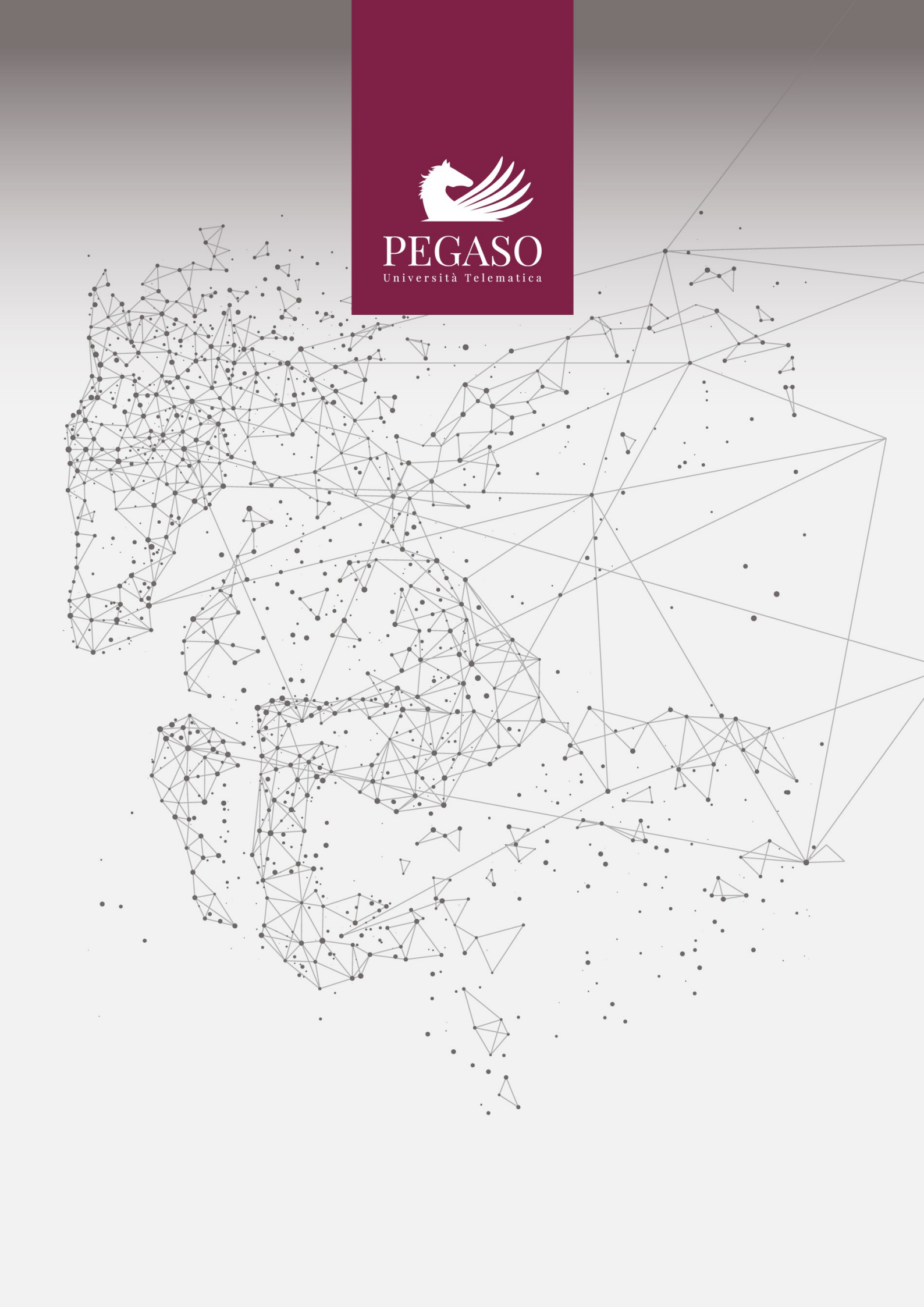

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 SICUREZZA DELLE INFORMAZIONI 3

2 L'ARCHITETTURA DI SICUREZZA DEL MODELLO OSI 5

3 ATTACCHI PASSIVI 7

4 ATTACCHI ATTIVI 9

BIBLIOGRAFIA 12

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Sicurezza delle informazioni

La sicurezza delle informazioni, prima della diffusione dei sistemi di elaborazione, era garantita tramite:

- mezzi fisici, i documenti venivano riposti in armadi metallici e casseforti
- mezzi amministrativi, vincoli di riservatezza a livello contrattuale per il personale di un'organizzazione.

L'introduzione dei computer ha reso necessario l'uso di strumenti automatizzati per la protezione dei file e di altre informazioni memorizzate.

Successivamente, la diffusione delle reti e dei sistemi di comunicazione ha richiesto lo sviluppo di meccanismi per proteggere i dati durante la loro trasmissione.

Vediamo adesso alcune importanti definizioni che sono alla base del presente corso di studi.

- **Computer security**: l'insieme degli strumenti destinati alla protezione dei dati e alla difesa dagli hacker.
- **Network security**: l'insieme delle misure adottate per proteggere i dati durante la loro trasmissione
- **Internet security**: l'insieme delle misure adottate per proteggere i dati durante la loro trasmissione attraverso una serie di reti interconnesse.

Come appare chiaro, i confini fra questi forme di sicurezza non sono ben definiti ed esiste una certa sovrapposizione.

Per avere un'idea di ciò di cui ci occuperemo, vediamo di seguito alcuni esempi di violazione della sicurezza che ovviamente non ne esauriscono l'ampia gamma.

1. L'Utente A invia all'Utente B un file con informazioni delicate e assolutamente riservate; l'Utente C, non autorizzato a leggere tale file, monitora tale trasmissione e ne cattura una copia.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. L'Amministratore D trasmette un messaggio ad un computer E per aggiungere nuovi utenti ad un file contenente la lista delle autorizzazioni; l'Utente F intercetta il messaggio, lo modifica e poi lo inoltra al computer E che lo accetta (come se venisse dall'Amministratore D) ed esegue l'operazione.
3. In questo caso, l'Utente F costruisce un proprio messaggio e lo trasmette al computer E fingendosi l'Amministratore D. Il computer E esegue quindi il comando ricevuto.

Quando si deve progettare un sistema di sicurezza non si devono valutare solo le possibili soluzioni tecnologiche ma sono molti gli aspetti che devono essere presi in considerazione. In primis, è molto importante analizzare i potenziali attacchi a cui il sistema può essere sottoposto anche se non si riesce a farlo in maniera esaustiva. Dopo di ciò è fondamentale considerare il contesto operativo in cui i vari meccanismi di sicurezza si troveranno ad operare definendone il loro posizionamento fisico (per esempio il punto della rete) e logico (per esempio il livello di un'architettura TCP/IP – Transmission Communication Protocol/Internet Protocol). Altro aspetto determinante riguarda la gestione delle informazioni segrete (per esempio una chiave crittografica) che spesso sono indispensabili per il funzionamento dei meccanismi di sicurezza; bisogna definire come tali informazioni vengono generate, distribuite e soprattutto protette. Infine non sono da trascurare gli aspetti implementativi ovvero come l'inserimento degli strumenti di sicurezza va ad impattare sulla realizzabilità pratica dell'intero sistema, per esempio se sono indotti dei ritardi eccessivi o imprevedibili non sostenibili dalla procedura per cui si è introdotto un certo sistema di sicurezza.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 L'architettura di sicurezza del modello OSI

Definire i requisiti di sicurezza necessari e caratterizzare gli approcci che soddisfano tali requisiti è un compito molto difficile. Tale compito, seppur già complicato in un ambiente centralizzato di elaborazione dati, lo è ancor di più a causa dell'utilizzo di reti locali e geografiche. A tale proposito, la *raccomandazione X.800 dell'ITU-T, Security Architecture for OSI*, stabilisce un approccio sistematico basato sulla definizione di **Attacchi alla sicurezza, Meccanismi di sicurezza e Servizi di sicurezza**. Di seguito vengono elencate tali definizioni specifiche:

- **Attacco alla sicurezza**: qualsiasi azione che compromette la sicurezza delle informazioni di proprietà di un'organizzazione
- **Meccanismo di sicurezza**: processo progettato per rilevare, prevenire o riparare i danni prodotti da un attacco alla sicurezza.
- **Servizio di sicurezza**: servizio che migliora la sicurezza dei sistemi di elaborazione e trasmissione delle informazioni di un'organizzazione. I servizi proteggono dagli attacchi alla sicurezza e sfruttano uno o più meccanismi.

Sempre nell'ottica di fornire delle importanti definizioni in ambito di sicurezza, la RFC 2828 specifica la differenza esistente fra due termini che spesso sono utilizzati come sinonimi ma che in realtà non lo sono, ovvero **Minaccia** e **Attacco**. Di seguito le definizioni precise:

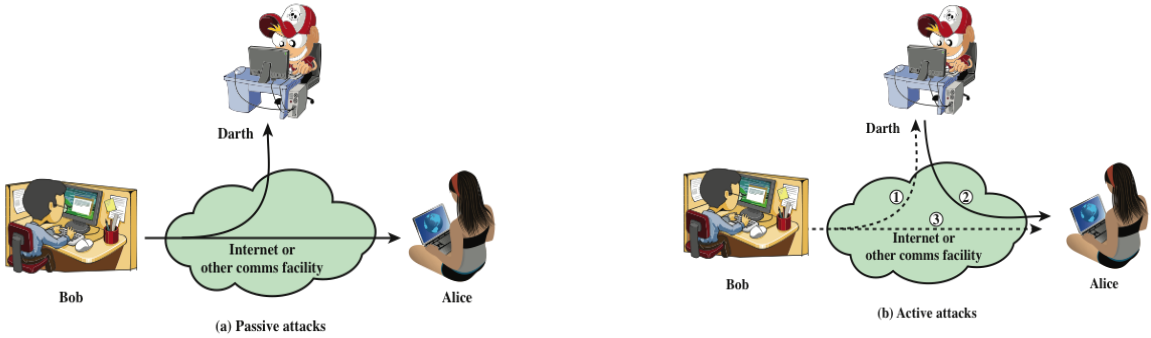
- **Minaccia**: potenziale violazione alla sicurezza determinata da una circostanza, un'azione o un evento che potrebbe violare la sicurezza e provocare danni. Quindi è un potenziale pericolo.
- **Attacco**: assalto alla sicurezza di un sistema ovvero tentativo deliberato di eludere i servizi di sicurezza e di violare la politica di sicurezza di un sistema.

Gli attacchi alla sicurezza possono essere di due tipologie distinte: gli **attacchi passivi** e gli **attacchi attivi**. Un attacco passivo tenta di rilevare o utilizzare le informazioni del sistema ma non agisce sulle sue risorse, mentre un attacco attivo tenta di alterare le risorse di un sistema o

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

comunque di alterarne il funzionamento. Nella figura seguente sono rappresentate, a livello generale, le due possibili situazioni di attacco.

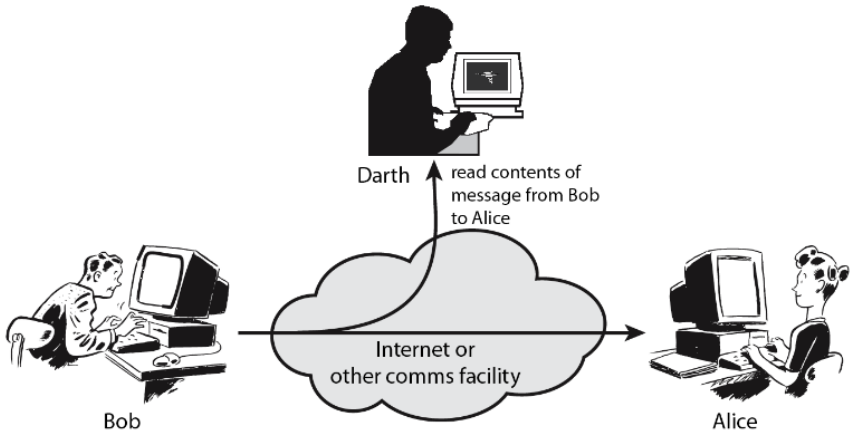


Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Attacchi passivi

Gli Attacchi passivi si preoccupano di intercettare o monitorare le trasmissioni, cercando di carpire le informazioni trasmesse. Tali attacchi sono molto difficili da rilevare poiché non comportano alcuna alterazione dei dati e, in pratica, i messaggi sono inviati e ricevuti in maniera apparentemente normale senza che né il mittente né il destinatario si rendano conto che qualcuno ha letto i messaggi o sta osservando la loro conversazione. Si capisce bene che la difesa da tali attacchi riguarda più che altro la prevenzione piuttosto che la rilevazione, ovvero si tende a realizzare dei meccanismi che impediscano l'attuazione dell'attacco o ne limitino la sua efficacia.

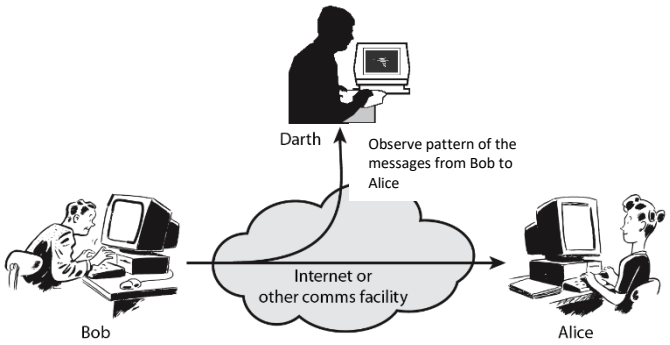
Un caso tipico di attacco passivo è l'**Intercettazione del contenuto dei messaggi**, per esempio un attaccante riesce ad entrare in possesso del contenuto di una conversazione telefonica, di un messaggio di posta elettronica o di un file che contiene informazioni delicate (informazioni bancarie, sanitarie, ecc.). Nella figura seguente viene proposta una rappresentazione di tale tipo di attacco. Darth, l'attaccante, riesce a carpire informazioni su ciò che Bob sta trasmettendo ad Alice; di solito, né Bob né Alice si accorgono che la loro comunicazione è sottoposta all'attacco di intercettazione di Darth.



Intercettazione del contenuto dei messaggi

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Un altro caso di attacco passivo è rappresentato dall'**Analisi del traffico**; in tale circostanza, sebbene il contenuto dei messaggi possa essere mascherato (cifrato) in modo tale che se anche intercettato non sia utilizzabile, un estraneo potrebbe comunque individuare informazioni quali la posizione e l'identità degli host, la frequenza e la lunghezza dei messaggi, ecc. Tale acquisizione di informazioni può permettere all'attaccante di dedurre lo stesso delle conoscenze sulla comunicazione in corso tra Bob e Alice, per esempio attraverso una analisi statistica delle caratteristiche di tali trasmissioni osservate in un certo intervallo temporale.



PEGASO
Università Telematica

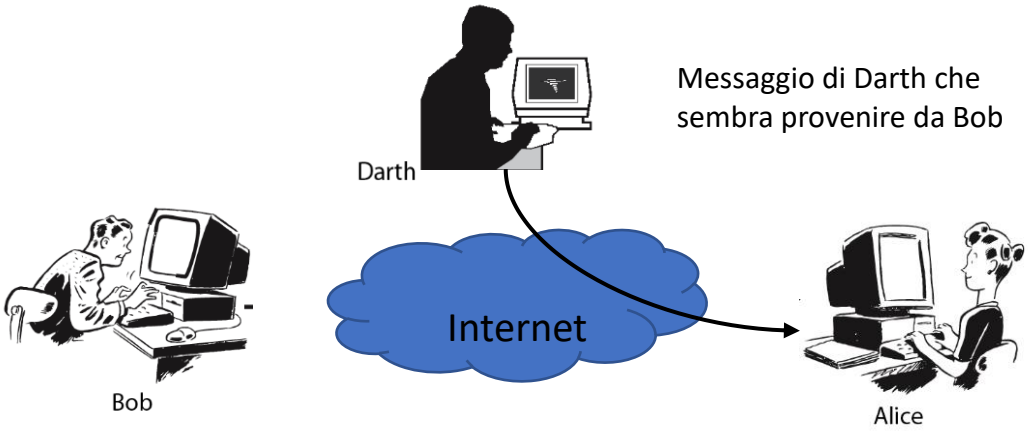
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

4 Attacchi attivi

Gli Attacchi attivi prevedono, differentemente da quelli passivi, una modifica del flusso dei dati o la creazione di un falso flusso. Sono generalmente divisi in 4 categorie:

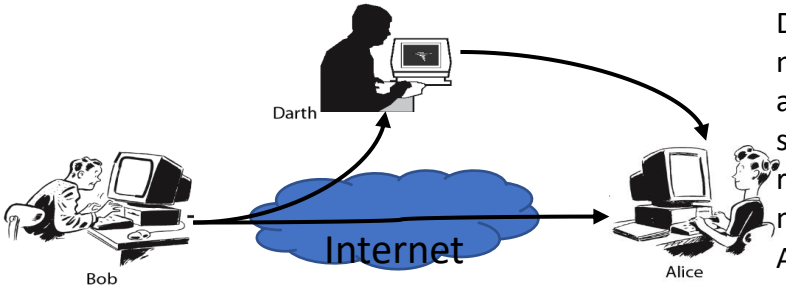
- *mascheramento*
- *ripetizione*
- *modifica dei messaggi*
- *denial-of-service (DoS)*

L'attacco di **Mascheramento** si verifica quando una determinata entità finge di essere un'altra entità, ovvero si "maschera" come tale. Questo è il classico caso in cui l'attaccante cerca di presentarsi di fronte ad un altro utente, ad un servizio o ad un account simulando di essere in possesso delle autorizzazioni di un altro soggetto: il classico caso è quello di un attaccante che cerca di fornire le credenziali corrette di accesso all'account di posta elettronica o di home banking di un'altra persona. Nella figura di seguito è rappresentato tale tipo di attacco.



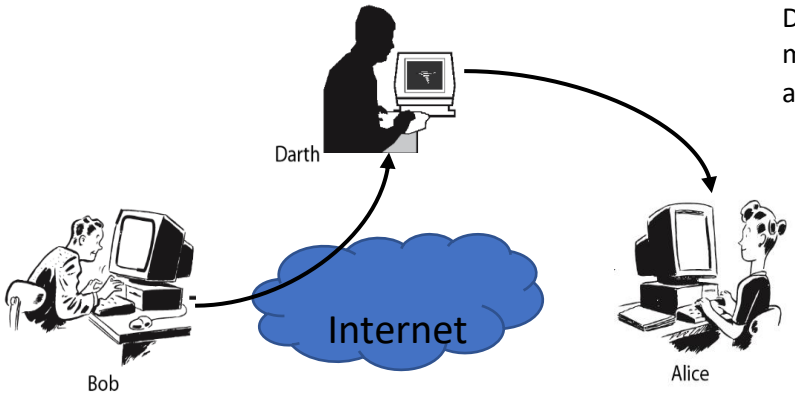
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

L'attacco di **Ripetizione** prevede invece la cattura passiva di un'unità dati e la sua successiva ritrasmissione per produrre un effetto non autorizzato. In questo caso l'attaccante entra in possesso, tramite un attacco passivo di intercettazione, di informazioni riservate (per esempio, username e password) che può in seguito reinviare (ripetere) al destinatario Alice per ottenere accesso ad un certo servizio riservato a Bob. Di seguito in figura è proposto una rappresentazione dell'attacco.



Darth cattura un messaggio da Bob ad Alice, successivamente ripeterà il messaggio ad Alice.

L'attacco di **Modifica dei messaggi** invece effettua un'alterazione di un messaggio legittimo oppure ne determina il ritardo o il riordino per produrre effetti non autorizzati. Il classico caso è quando un messaggio che proviene da Bob con un determinato contenuto ("effettua un bonifico da 10K€ a John") viene intercettato e alterato nel contenuto ("effettua un bonifico da 50K€ a Darth") e reinviato, in sostituzione dell'originale, al destinatario Alice come se venisse da Bob. In figura è proposta un'illustrazione di tale attacco.

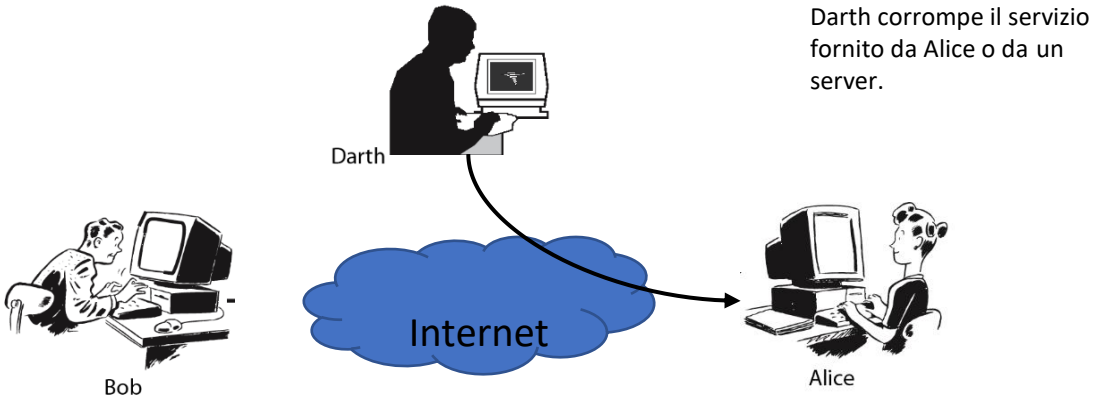


Darth modifica il messaggio da Bob ad Alice.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

L'attacco di **Denial-of-service (DoS)** invece non prevede interazione con il mittente e tende ad impedire il normale utilizzo o la gestione di un sistema di comunicazione. Tale attacco può mirare a sopprimere tutti i messaggi diretti ad una certa destinazione oppure a sovraccaricare di messaggi una rete o un server per degradarne le prestazioni. Ciò accade nel caso di server sottoposti in maniera malevola a una moltitudine di richieste tali da determinarne un sovraccarico e conseguentemente un disservizio. In figura una rappresentazione dell'attacco DoS.



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: Introduzione.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).